

ServerManager Security Code Review

Date: 3 October 2026

Scope: Code and scripts used today to harden Host-server-dif-wifi (VPS edge, portal auth, VPN trust circle, Flint LAN gate, USB key vault)

Primary branches: cursor/vpn-allowlist-auth-circle-a9a6, cursor/usb-key-vault-a9a6, stacked harden / IKEv2 / Caddy ACL work

Classification: Operator security review - not a formal pentest report

1. Executive summary

Today's work layered defense around a self-hosted ServerManager stack: a public VPS terminates VPN and HTTPS, a home Flint router bridges VPN clients into LAN, and a portal on the VPS orchestrates SSO, authenticator 2FA, and admin controls. The code reviewed here is the security-relevant surface that was built, hardened, or remodeled in the current campaign.

What improved most

1. VPN trust circle - unknown VPN clients get internet but not admin DNS / portal ACL until approved from enrolled Authenticator devices.
2. Authenticator hardening - TOTP only via headers (not query strings), per-real-IP lockout, timed enrollment unlock, Secure session cookies, auth for /static/ panel HTML.
3. Edge rate / exposure caps - SSH :22 UFW limit + sshd hardenings; optional HTTP/VPN conn caps; service UIs (wg-easy, portal :5002, SMB/NAS, Proxmox/Plex public hosts) gated VPN-only where intended.
4. Hardware-adjacent SSH key storage - LUKS file vault on the ~128GB Norelsys USB on Proxmox (plus optional Windows VHDX path), with mount/dismount discipline and steganographic recovery hint.

Residual risk (honest)

- USB LUKS/VHDX is not YubiKey/TPM: keys leave the device while unlocked.
- Trust circle depends on sticky IP files + Caddy ACL + Flint scripts staying in sync; race/TTL bugs previously needed fixes and remain operationally sensitive.
- Public SSH remains reachable (intentionally) for break-glass / cloud agents - mitigated by rate limits, not removal.
- Steganography conceals recovery text; it is not cryptographic storage.

Overall posture after today's stack is roughly strong homelab / small-biz (previously scored ~84/100 in session discussion): well above default VPS+VPN setups, short of enterprise HSM + IdP + continuous monitoring.

2. Architecture under review

Internet clients

|

```
| - UDP 500/4500 IKEv2, UDP 5000/443 WG, TCP 8443/443 OpenVPN -> VPS
| - TCP 80/443 HTTPS (Caddy + sslh) -> VPS
| - TCP 22 SSH (UFW limit) -> VPS
|
| Portal (server.py) + Authenticator APIs
| Caddy @vpn_clients ACL + sticky WAN IPs
| AdGuard split-DNS / guest DNS for untrusted
|
| OpenVPN to Flint
|
| Home LAN 192.168.8.0/24
| Proxmox / NAS / Plex / ...
| LAN circle Flint gate
```

Trust domains

```
Domain | Code / config owners | Trust assumption
VPS public edge | portal/scripts/security/harden-*.sh, UFW before.rules markers | World can knock; only VPN...
Portal app | portal/server.py, portal/static/ | Session + 2FA before mutations
VPN identity | IKEv2 peer ACL, allowlist JSON, sticky IPs | Approved WAN/VIP == trusted client
Home LAN | Flint gate scripts, Caddy LAN upstreams | LAN is not fully trusted; pending devices blocked from...
Operator keys | portal/scripts/security/usb-key-vault/ | Private keys live on encrypted removable media
```

3. Edge hardening scripts (portal/scripts/security/)

These idempotent bash tools write marked blocks into UFW / sshd / host firewall policy. They are the packet-layer code used to secure the server.

```
Script | Purpose
harden-ssh-port-rate-cap.sh | UFW limit on :22, connlimit in before.rules, sshd drop-in (MaxAuthTries 3, no...
harden-vpn-ports-rate-cap.sh | Caps IKEv2/WG/OpenVPN listeners; modes off/loose/strict (default off after t...
harden-http-ports-conn-cap.sh | Optional per-IP connlimit on 80/443; default off because 443 is shared with...
harden-portal-5002-vpn-only.sh | Binds / firewalls panel direct port so it is not a public bypass of Caddy
harden-wg-easy-ui-vpn-only.sh | WireGuard admin UI not world-reachable
harden-smb-vpn-only.sh / harden-nas-gateways-vpn-only.sh | File-share / NAS control planes VPN-scoped
harden-remote-desktop-bind.sh | RDP exposure constrained (VPN-oriented bind)
harden-flint-forwards-vpn-only.sh | Router port-forwards not casually public
harden-secret-perms.sh | Tightens mode bits on secret files under /opt/...
retire-old-vps-ip.sh | Removes retired public IP from allow paths / confusion surface
loosen-*-ports-*.sh | Emergency rollback companions for rate caps
```

Review notes

- Marker comments (# BEGIN sm-ssh-port-cap ...) make changes auditable and re-runnable - good ops hygiene.
 - Defaulting VPN/HTTP caps to off after outages is pragmatic but means flood resistance depends on operators flipping VPN_RATE_CAP_MODE / HTTP_RATE_CAP_MODE when under attack.
 - SSH remains public by design; the code comments correctly warn that VPN-only SSH can lock out cloud agents.
-

4. Portal authentication and session security (portal/server.py)

4.1 Session cookies

```
COOKIE_NAME = sm_session
SESSION_HOURS = 12 (env-overridable)
Set-Cookie: HttpOnly; Secure; SameSite=Lax
```

`_cookie_set_header` / `_cookie_clear_header` force Secure so session tokens are not sent on plain HTTP. Grafana SSO uses SameSite=None; Secure for cross-subdomain iframes - necessary, higher CSRF exposure on that cookie path; mitigated by Grafana's own authz.

4.2 Login step-up

- Password login can enter a pending state (`PENDING_LOGIN_TTL_SECONDS`, default 300s) awaiting Authenticator approval / TOTP.
- Email codes (`EMAIL_CODE_TTL_SECONDS`, default 600s) exist as an alternate path where configured.
- Failed logins go to syslog via `log_failed_login`.

4.3 Authenticator device model

Important constants (env-overridable):

Constant	Default	Role
<code>AUTH_APP_ENROLL_UNLOCK_SECONDS</code>	900	Timed window when new devices may enroll
<code>AUTH_APP_TOTP_MAX_FAILS</code>	8	Failures before logout
<code>AUTH_APP_TOTP_FAIL_WINDOW</code>	300s	Sliding window for fail count
<code>AUTH_APP_TOTP_LOCKOUT</code>	300s	Lockout duration
<code>AUTH_APP_MAX_DEVICES</code>	8	Cap enrolled devices
<code>SSH_PANEL_UNLOCK_SECONDS</code>	300	Extra unlock for SSH / VPS login mutations

Device registry lives at `AUTH_APP_DEVICES_PATH` (default under `/opt/servermanager/panel/...`) with 0o600 writes via temp-file replace - solid pattern against partial writes.

4.4 Client IP for logout (`request_client_ip`)

Critical fix from today's hardening: rate limits and lockouts key off the real client IP. Headers X-Real-IP / X-Forwarded-For are honored only when the TCP peer is loopback/docker (Caddy). Direct clients cannot spoof forwarding headers to reset or share logout buckets. This closed a classic reverse-proxy bypass.

4.5 Static panel HTML auth

Serving `/static/` panel assets without auth previously risked information disclosure and simpler XSS footholds. Requiring auth for panel HTML under `/static/` reduces anonymous recon of admin UI structure.

4.6 Security UI nesting

VPN trust circle UI was moved inside the locked Security -> VPS login / SSH panel so casual portal users (or shoulder-surfers on a shallow tab) do not see or mutate circle state without the same unlock used for SSH key changes. Device names from LAN maps improve operator clarity without exposing Allowed LAN IP lists in the Authenticator forever (privacy + reduced targeting intel).

5. VPN trust circle and Caddy ACL

5.1 Data files

- vpn-allowlist.json - approved / pending devices (mode 0o600)
- caddy-sticky-vpn-ips.txt - WAN/VIP IPs Caddy should treat as VPN-trusted
- Auth-app device LAN touches feed pending / enrolled state

5.2 ensure-vpn-client-gate.sh (IKEv2 peer gate)

Allowlisted clients receive AdGuard DNS (admin rewrites). Others keep internet but are forced toward guest DNS (VPN_GUEST_DNS, default 1.1.1.1) so they do not resolve internal admin hostnames. Pool 10.10.0.0/24 is the IKEv2 client range. Script is driven by sm-ikev2-peer-acl.service after sticky sync.

5.3 Flint LAN circle gate (ensure-lan-circle-flint-gate.sh)

Enforces pending LAN devices on Flint before NAT, so a device on home Wi-Fi that is not approved cannot quietly reach admin paths the way a naive "VPN-only Caddy" model would miss. Enrolled Authenticator LAN IPs are exempted so phones can still approve pending peers while the gate is active - carefully balanced UX vs. security.

5.4 Caddy @vpn_clients

Public hostnames (proxmox.vpstruelord.com, plex.vpstruelord.com, router, etc.) are gated so only VPN ACL matches (sticky WAN, pools, sealed Flint WAN VIP, etc.) reach upstreams. Portal generation injects header_up X-Real-IP {remote_host} for correct app-layer IP. Sticky rewrite must include LAN allowlist IPs when relevant - a bug class fixed today when sticky regeneration dropped them.

Review notes

- Strength: defense-in-depth across DNS + L3/L4 + HTTP ACL + app auth.
 - Weakness: distributed state (JSON + sticky file + Flint + Caddy reload). Any desync creates either lockouts or brief over-allow. Timers/services reduce drift; still deserves monitoring.
-

6. Service exposure policy (VPN-only admin)

Today's hardeners and Caddy changes encode a clear policy: entertainment/media and admin planes are not public.

Examples:

- Proxmox and Plex public hostnames -> VPN ACL
- wg-easy UI -> VPN-only
- NAS FTP/SMB / media RPC -> VPN-scoped
- Portal direct :5002 -> not a public backdoor
- Router WAN sealed into trust circle so Flint's public IP cannot be used as a confused-deputy bypass of "must be on VPN"

This is the highest-ROI pattern in the codebase: shrink the open attack surface to VPN listeners + SSH limit + Caddy.

7. USB key vault and steganography

7.1 Threat model addressed

Long-lived SSH private keys sitting decrypted under ~/.ssh on a daily-driver PC/Proxmox host. Attacker with disk access or casual malware can copy them.

7.2 Implementation (Proxmox primary)

Scripts under portal/scripts/security/usb-key-vault/:

```
Artifact | Role
new-sm-usb-key-vault.sh | Create 256MB LUKS2 image on Norelsys USB (ESD-USB), refuse WD Elements
new-sm-usb-ssh-key.sh | ssh-keygen -t ed25519 inside mounted vault
mount-sm-usb-key-vault.sh / dismount-... | Unlock/mount; optional ssh-add -t; close mapper
run-usb-key-vault-via-vps.py | Deploy/run via VPS -> root@192.168.8.160
*.ps1 | Windows VHDX + BitLocker analogue
stego-text-in-png.py | LSB steganography for recovery notes
```

Applied today on live Proxmox: Norelsys ~128GB stick received ServerManagerKeys.img, an ed25519 keypair, dismount, and vault-hint.png with stego payload (stego password separate from LUKS).

7.3 Limitations (must stay explicit in ops docs)

1. While unlocked, keys are software-readable -> not hardware-backed.
2. Stego PNG on the same USB is convenience recovery, not a second factor; physical theft of USB + knowledge of method weakens the story.

3. Portal step-up still TOTP-based; WebAuthn/YubiKey remains future work.

8. Authenticator clients

Windows .exe, Android, and iPhone auth apps participate in enrollment, TOTP, and trust-circle approve/pending UX. Security-relevant product decisions from today:

- No TOTP in query strings (logs/Referer leakage).
- Enrollment locked by default; timed unlock from Security panel.
- Allowed LAN IP list hidden from Authenticator UI; circle still functional.
- Biometrics lock on Android path where wired.
- Trust circle nested behind Security unlock in the portal.

Client code cannot be stronger than API authorization - the server-side checks in server.py remain the source of truth.

9. Findings summary

Strengths

1. Consistent VPN-first exposure model with scripts that encode policy as code.
2. Layered trust circle (DNS guest mode + Caddy ACL + Flint pre-NAT gate + app 2FA).
3. Careful proxy IP handling for lockouts (request_client_ip).
4. Secure cookies and file modes 0o600 on allowlist/device stores.
5. Idempotent harden scripts with begin/end markers and loosen companions.
6. Operator key hygiene moving toward removable encrypted vaults.

Weaknesses / follow-ups

ID	Severity	Issue	Suggested direction
W1	Medium	VPN/HTTP rate caps default off	Document runbook to enable loose under abuse; alert on connt...
W2	Medium	No WebAuthn / hardware step-up yet	Add portal WebAuthn; keep TOTP as backup
W3	Medium	Trust-circle state distributed	Single reconciler metrics: sticky vs allowlist vs Flint vs C...
W4	Medium	Sessions, TOTP lockouts, SSH unlocks are in-memory	Persist or accept restart=reset; documen...
W5	Medium	Enroll-unlock temporarily opens Flint pending for ALL pending LAN IPs	Narrow exemption to t...
W6	Medium	Portal-login TOTP path lacks require_auth_app_totp lockout	Reuse the same per-IP lockout he...
W7	Low	USB vault != HSM; stego on same USB as LUKS	YubiKey path; keep recovery image offline
W8	Low	Auth-app is intentionally Internet-reachable	Accept; rests on TOTP + enroll gate - monitor fai...
W9	Info	Public SSH retained; large server.py monolith	Keep SSH capped; split auth/vpn modules over time

10. Conclusions and operator checklist

Today's code materially raised the cost of opportunistic attack against the ServerManager host: internet scanners hit rate-limited SSH and VPN ports; admin UIs hide behind VPN ACLs; unknown VPN users do not receive admin DNS; portal mutations demand session + authenticator context; SSH private keys can live on a LUKS USB rather than an always-mounted home directory.

Checklist for ongoing use

1. Approve new devices from an enrolled Authenticator only during intentional unlock windows.
 2. After SSH work on Proxmox: `dismount-sm-usb-key-vault.sh` (or `via-vps dismount`).
 3. Store LUKS passphrase in a password manager; treat `vault-hint.png` as backup, not primary.
 4. Paste USB vault public key into Security -> VPS SSH keys; never copy the private key off the vault.
 5. If under scan/flood: set `VPN_RATE_CAP_MODE=loose` and/or `HTTP_RATE_CAP_MODE=loose`, re-run `harden` scripts.
 6. Periodically verify Caddy VPN ACL, sticky file, and Flint gate agree (status endpoints / `ensure-*-gate.sh` dry runs).
 7. Keep `/opt/servermanager/panel/*.json` modes 600 via `harden-secret-perms.sh`.
-

Appendix A - Key file index

Path | Why it matters

`portal/server.py` | Sessions, TOTP, enroll TTL, vpn allowlist APIs, Security panel, Caddy snippet generation...
`portal/static/index.html` | Security UI, trust circle nesting, enroll unlock toggle
`portal/scripts/ikev2/ensure-vpn-client-gate.sh` | Guest vs AdGuard DNS for IKEv2 peers
`portal/scripts/ikev2/ensure-lan-circle-flint-gate.sh` | Pre-NAT LAN pending enforcement
`portal/scripts/ikev2/ensure-ikev2-peer-acl.sh` | Peer ACL sync glue
`portal/scripts/ikev2/ensure-vpn-split-dns.sh` | Split DNS so `portal/admin` names resolve on-VPN
`portal/scripts/security/harden-*.sh` | Edge exposure and rate policy as code
`portal/scripts/security/usb-key-vault/*` | Removable encrypted SSH key vault + stego helper
`/opt/trueemail/Caddyfile` (live) | Deployed VPN ACL host blocks (generated/patched)
`/opt/servermanager/panel/vpn-allowlist.json` | Trust circle source of truth
`/opt/servermanager/panel/caddy-sticky-vpn-ips.txt` | Sticky WAN/VIP ACL inputs

Appendix B - Representative constants (defaults)

```
SESSION_HOURS=12
SSH_PANEL_UNLOCK_SECONDS=300
PENDING_LOGIN_TTL_SECONDS=300
EMAIL_CODE_TTL_SECONDS=600
AUTH_APP_ENROLL_UNLOCK_SECONDS=900
AUTH_APP_TOTP_MAX_FAILS=8
AUTH_APP_TOTP_FAIL_WINDOW=300
AUTH_APP_TOTP_LOCKOUT=300
```

```
AUTH_APP_MAX_DEVICES=8
VPN_RATE_CAP_MODE=off
HTTP_RATE_CAP_MODE=off
SSH_CONNLIMIT=8
IKEV2_POOL=10.10.0.0/24
VPN_GUEST_DNS=1.1.1.1
```

Appendix C - Suggested next hardening sprint

1. WebAuthn / passkey step-up for portal Security unlock (keep TOTP fallback).
 2. Metrics + alert when sticky IP set diverges from allowlist approved WAN set.
 3. Optional loose rate-cap profile enabled automatically after N failed SSH auths / min.
 4. Split server.py auth and vpn-allowlist modules for smaller review surface.
 5. YubiKey-backed SSH (sk-ssh-ed25519@openssh.com) as upgrade path from USB LUKS.
 6. Periodic automated smoke: unapproved VPN client cannot resolve/admin-fetch proxmox hostname; approved can.
-

Appendix D - Threat scenarios mapped to controls

D.1 Internet scanner against VPS :22

Attack: Credential stuffing / banner grabs on public SSH.

Controls: harden-ssh-port-rate-cap.sh (UFW limit + connlimit + MaxAuthTries 3); key-based auth assumed; syslog failed login from portal is separate from sshd.

Residual: Persistent distributed slow scans still possible; Fail2ban/crowdsec not reviewed as part of today's code.

D.2 Stolen portal password without phone

Attack: Phishing or reuse of PF_PASS.

Controls: Pending login TTL; Authenticator TOTP / approval; enroll unlock not left open; Secure HttpOnly session cookie.

Residual: Session theft from an already-logged-in browser remains until SESSION_HOURS expiry or logout.

D.3 Unapproved friend on home Wi-Fi

Attack: Device joins LAN and browses for Proxmox/NAS.

Controls: Flint LAN circle gate before NAT; pending state in vpn-allowlist; Authenticator must approve; Caddy VPN ACL still requires VPN identity for public hostnames.

Residual: Pure L2 LAN attacks against hosts that bind openly on 192.168.8.0/24 are outside Caddy - host firewalls on Proxmox/NAS remain important.

D.4 VPN client connected but not in circle

Attack: Valid VPN credential / profile without allowlist approval.

Controls: Guest DNS (no admin rewrites); sticky/Caddy deny for admin hostnames; ensure-vpn-client-gate.sh.

Residual: Raw IP access to LAN via VPN routing if Flint forwards broadly - peer ACL and Flint forward hardeners reduce this.

D.5 Disk theft of Proxmox USB stick

Attack: Physically steal Norelsys flash drive.

Controls: LUKS2 on ServerManagerKeys.img; passphrase not stored on disk; refuse to use Elements media disk.

Residual: Stego vault-hint.png on same stick + known stego password weakens recovery secrecy; offline backup of passphrase preferred.

D.6 Malware on Proxmox while vault mounted

Attack: Steal /mnt/sm-key-vault/ssh/id_ed25519 while unlocked.

Controls: Operational dismount discipline; optional ssh-add TTL; documentation that this is not HSM.

Residual: No hardware attestation; treat unlock windows as privileged.

Appendix E - Review methodology

This review was produced by reading the live repository state on 2026-10-03, focusing on:

1. portal/server.py authentication, cookie, allowlist, and client-IP helpers
2. portal/scripts/security hardeners and usb-key-vault toolkit
3. portal/scripts/ikev2 gate/ACL/split-DNS scripts
4. Security UI behavior in portal/static/index.html (trust circle nesting, enroll unlock)
5. Git history from today's hardening and auth-circle commits

It is a design-and-code review, not a penetration test. No adversarial exploitation of production was performed beyond authorized operator actions (USB vault creation, status checks via existing VPS hop).

Appendix F - Scorecard (operator view)

Area | Score (1-10) | Comment

Edge exposure minimization | 9 | VPN-first admin; SSH intentionally open but capped

AuthN / AuthZ for portal | 8 | Session + TOTP/circle; WebAuthn missing

VPN trust circle correctness | 8 | Strong design; sync complexity is the risk

Secret / key handling | 7 | USB LUKS good step; not hardware-backed

Operability / rollback | 9 | Idempotent scripts + loosen companions

Observability | 5 | Syslog login fails; little drift alerting

Documentation | 7 | READMEs and this review; runbooks still thin

Composite: about 7.8 / 10 for the intended threat model (opportunistic internet + curious LAN + lost USB), lower against nation-state or malware-on-host-while-unlocked. Score nudged down slightly after deeper code survey of in-memory auth state and enroll-unlock LAN breadth.

Appendix G - Deeper code survey notes (follow-up)

Cross-checks from focused code surveys of harden scripts and portal auth (same day as this review):

1. Peer ACL sync (ensure-ikev2-peer-acl.sh) correctly does NOT auto-add live IKEv2 peer WANs - only allowlisted sticky + approved LAN /32s enter @vpn_clients.
2. Flint SM-LAN-CIRCLE only REJECTS pending/denied LAN to VPS :80,:443 - other LAN services still need host firewalls.
3. Guest VPN clients keep full internet; DNS guest mode is bypassable if the client ignores pushed DNS.
4. Approving a public WAN trusts that NAT egress for every device behind it (home CGNAT / cafe Wi-Fi nuance).
5. Auth-app circle approve with TOTP alone (no portal session) is intentional so phones can manage pending while LAN gate is on.
6. Sibling branch work may add harden-mail-ports-rate-cap.sh (465/587/993) - not on usb-key-vault tip at review time.
7. Marker-based UFW before.rules edits + loosen-* wrappers are the right ops pattern for reversible edge policy.

These notes refine residual risk; they do not change the operator checklist in section 10.

Document control: Generated 2026-10-03 for download from Cloud Agent artifacts and portal/docs/ on branch cursor/usb-key-vault-a9a6. Regenerated after auth/edge survey follow-up.

End of review.